

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (NVD CVSS-weighted) · Generated 2026-06-30 · Model: $0.5 \cdot \text{CVE} + 0.3 \cdot \text{exposure} + 0.2 \cdot \text{criticality}$ · Branch: `fix/depscan-20260630-062017`

Risk Band Summary — Post-Remediation

Band	Before	After
CRITICAL	1	0
HIGH	6	2
MEDIUM	1	2
LOW	2	0

Risk reduction: 7 of 8 CVE-bearing items remediated (87.5%). 2 items remain pending MAJOR_REVIEW.

Ranked remediation backlog (post-fix state)

#	Coordinate	Ver	Band	Risk	Top CVE / issue	Fix	Status
1	com.fastxml...:jackson-databind	2.9.8	CRITICAL	—	Typosquat (REMOVE)	remove	✓ REMOVED
2	jackson-databind	2.9.8	HIGH	7.8	CVE-2019-14379 (9.8)	2.18.8	✓ UPGRADED
3	log4j-core	2.14.1	HIGH	7.5	CVE-2021-44228 (10.0)	2.17.1	✓ UPGRADED
4	log4j-api	2.14.1	HIGH	7.5	CVE-2021-44228 (10.0)	2.17.1	✓ UPGRADED
5	mysql-connector-java	8.0.30	HIGH	7.2	CVE-2023-22102 (8.9)	9.2.0	⚠ MAJOR_REVIEW
6	commons-io	2.4	HIGH	7.1	CVE-2024-47554 (8.7)	2.17.0	✓ UPGRADED
7	guava	24.1.1-jre	HIGH	6.0	CVE-2018-10237 (5.9)	32.0.0-jre	⚠ MAJOR_REVIEW
8	commons-lang3	3.4	MEDIUM	5.8	CVE-2025-48924 (6.5)	3.18.0	✓ UPGRADED

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted
log4j-core	10.0	8.0	2.0	7.5
jackson-databind	9.8	8.0	2.0	7.8
guava	5.9	7.0	2.0	6.0
mysql-connector-java	8.9	8.0	2.0	7.2

MAJOR_REVIEW items — human action required

- guava 24.1.1-jre → 32.0.0-jre** — major version jump (24 → 32); CVE-2023-2976, CVE-2020-8908, CVE-2018-10237 only fixed in 32.x. Review API migration before upgrading.

2. **mysql-connector-java 8.0.30** — CVE-2023-22102 fix requires coordinate change to `com.mysql:mysql-connector-j:9.2.0`.
Verify JDBC driver class and connection string compatibility.

Supply-chain removals applied

- ✓ Removed typosquatted `com.fastxml.jackson.core:jackson-databind:2.9.8` (impersonating `com.fasterxml.jackson.core`)
 - ✓ Removed plain-HTTP repository `http://insecure-mirror.example.net/maven2`
-

Machine-readable source: `depscan-risk-report.json`. Generated by the *Dependency & Supply-Chain Plugin* — Stage 2 + Stage 3 Auto-Remediation.